

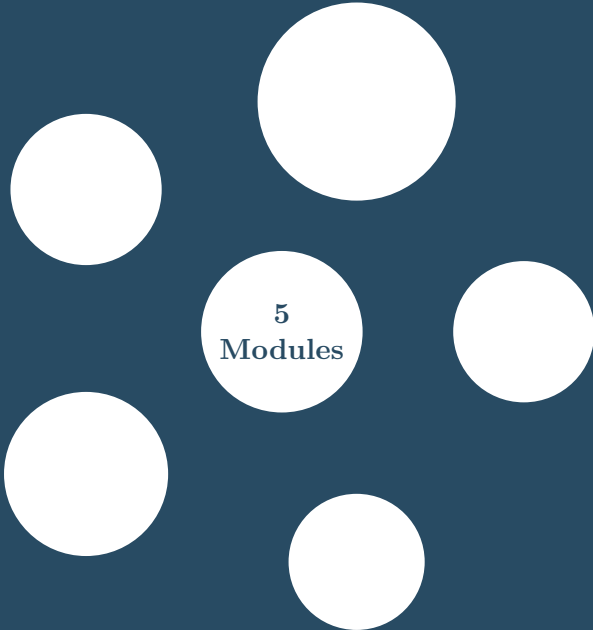


NIS2

NIS2 Management Training

Everything the Directive Requires
a Member of the Management Body to Know

Structured around the BSI's three competence areas
and the ten Article 21 measures



5
Modules

About this book

This book is a print-ready version of the NIS2 Management Training course available at www.nisd2.eu. It follows the three competence areas required by Article 20(2) of the NIS2 Directive: identifying risks, assessing the measures used to manage them, and understanding how those risks affect the services your company delivers.

Not legal advice. This course teaches the EU directive and the concepts behind it. It is not legal advice, and no body in the European Union currently certifies NIS2 trainers or training programmes. This document is training material, not a legal certification.

German standard. Throughout this course we reference the German implementation, the BSIG and the BSI, because Germany's transposition is the strictest in the EU. If you build your compliance to the German standard, you meet or exceed requirements in every other member state.

Passing score. Each lesson quiz requires 75% to pass.

© NISD2. All rights reserved.

Contents

About This Course	7
1 The Law	9
1.1 1.1 What NIS2 Is and Why It Exists	9
1.2 1.2 Who Is in Scope Essential vs Important Entities	11
1.3 1.3 Penalties and the Article 34 Manager Ban	12
1.4 1.4 The Registration Obligation	13
1.5 1.5 Your Duty to Approve and Oversee	14
1.6 1.6 Your Training Duty	14
1.7 1.7 Personal Liability Under Your Country's Corporate Law	15
1.8 1.8 The Business Judgment Rule Does Not Protect You	15
1.9 1.9 The Ten Measures - Overview	16
1.10 1.10 All-Hazards Approach and State of the Art	16
1.11 1.11 The Reporting Cascade and Significant Incidents	17
1.12 1.12 The Customer Notification Duty	17
2 Risk and the 10 Measures	19
2.1 2.1 Risk = Likelihood × Impact	19
2.2 2.2 What Is an Asset?	20
2.3 2.3 Risk Treatment Options and Risk Appetite	20
2.4 2.4 Why Risk Management Is Continuous	20
2.5 2.5 The CIA Triad and Business Impact	21
2.6 2.6 Measure 1 Risk Analysis and Information Security Policies	21
2.7 2.7 Measure 2 - Incident Handling	22
2.8 2.8 Measure 3 - Business Continuity	22
2.9 2.9 Measure 4 - Supply Chain Security	22
2.10 2.10 Measure 5 - Acquisition, Development, and Maintenance	23
2.11 2.11 Measure 6 - Effectiveness Assessment	23
2.12 2.12 Measure 7 - Cyber Hygiene and Training	23
2.13 2.13 Measure 8 - Cryptography	24
2.14 2.14 Measure 9 - HR Security, Access Control, and Asset Management	24
2.15 2.15 Measure 10 - Multi-Factor Authentication and Secured Communications	24
3 Decision Support	27
3.1 3.1 The Questions Every CEO Must Answer	27
3.2 3.2 Sign-Off in Practice	28
3.3 3.3 When to Re-Sign-Off	29
3.4 3.4 Red Flags in Your Team's Sign-Off Process	29
3.5 3.5 What You Cannot Delegate - The Checklist	29
3.6 3.6 CISO and Supervisory Board Reporting Lines	30
3.7 3.7 What Happens During a Regulator Audit	30

3.8	3.8	Scenario - Ransomware Hits Friday Afternoon	31
3.9	3.9	Scenario - Supplier Breach Affecting Your Customer Data	31
3.10	3.10	Scenario - Phishing Success: Significant or Not?	31
3.11	3.11	Scenario - Pre-Audit Gap Discovery	32
4		Protection	33
4.1	4.1	Insurance Is Not a Substitute for Controls	33
4.2	4.2	D&O Insurance - What It Covers and the Cyber Exclusions	33
4.3	4.3	Cyber Insurance vs D&O - Different Products, Different Coverage	34
4.4	4.4	Common Policy Exclusions to Read For	34
4.5	4.5	First 48 Hours of Crisis Communication	34
4.6	4.6	Ransomware Payment Decisions	35
5		Final	37
5.1	5.1	Your First 90 Days After This Course	37
5.2	5.2	Certificate of Completion	38
A		Answer Key	39
B		The Non-Delegable Checklist	41
C		The Eleven Required Policies	43
D		The BSI's 10 Questions Every CEO Must Answer	45
E		Glossary of Key Terms	47
		About NISD2	51

About This Course

EU law now requires every member of a management body of a covered company to personally undergo cybersecurity training. Not your CISO. Not your head of IT. **You.** Article 20(2) of the NIS2 Directive, written into national law in every EU country, names the leadership team directly.

Who this course is for

If you sit on the leadership team of a company covered by NIS2 as a CEO, managing director, executive board member, COO, CFO, or any role the law calls a “member of the management body” this course is for you. The law does not distinguish between the CEO and the rest of the leadership team. Every single member carries the same duty. **The training obligation is non-delegable.** You cannot send your CISO, your lawyer, or your assistant in your place.

What this course is

This is a structured course covering what the NIS2 Directive requires you to know as a member of the leadership team. It follows the three competence areas the law requires:

- **Identifying risks** understanding what threats your company faces
- **Assessing the measures** evaluating whether what your team has put in place actually works
- **Understanding service impact** connecting cybersecurity to your business operations

Forty-seven short lessons. Roughly four hours of content and review. After every lesson there is a short quiz. When you complete the course, the platform issues a Certificate of Completion in your name.

What this course is not

This course is not legal advice. This course is not a certified qualification. No body in the European Union currently certifies NIS2 trainers or training programmes.

How to use this book

Work through each chapter in order. After each lesson, complete the quiz. When a specific requirement lands a signature you have to give, a document you have to personally approve write it down. By the end you will have your own action list.

Key Takeaways

1. Article 20(2) of the NIS2 Directive personally requires every member of the management body to undergo cybersecurity training the duty is non-delegable.
2. No EU member state has established a state-backed certification for NIS2 training; the auditor judges sufficiency based on content covered, time spent, and documentation.

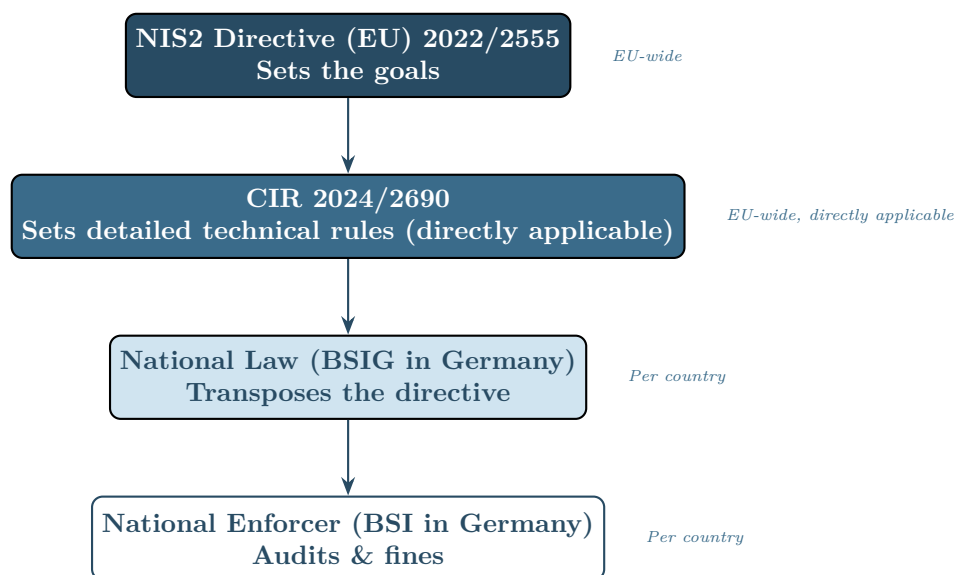
-
-
3. This course covers all three competence areas the law requires.

Chapter 1

The Law

Module 1 12 Lessons

This module covers the legal foundation of NIS2: what the law is, who it applies to, what it requires you personally to do, and what happens if you do not. By the end, you will be able to answer the five foundation questions the BSI expects every covered CEO to answer.



The full legal chain from EU directive to national enforcement.

1.1 **1.1** What NIS2 Is and Why It Exists

Roughly 160,000 companies across the European Union are now on a list the EU decided is too important to go dark. If your company is on that list, the rules governing your cybersecurity are no longer set by you, they are set by three layers of EU and national law, enforced by a national regulator.

The Directive

The formal name is Directive (EU) 2022/2555 the **NIS2 Directive**. Adopted on 14 December 2022, entered into force on 16 January 2023. It replaces NIS1, which was widely seen as inconsistent and weakly enforced, almost no fines were ever issued under NIS1 anywhere in the EU.

NIS2 is a **directive**, not a regulation. A regulation (like the GDPR) applies directly in every country. A directive tells each country what the result has to be, and each country writes its own national law. The directive is the floor, not the ceiling.

The Implementing Regulation (CIR)

Commission Implementing Regulation (EU) 2024/2690 is a regulation it applies directly in all 27 member states without transposition. The CIR sets the detailed technical requirements: what counts as a significant incident, what policies you must have, what thresholds trigger mandatory reporting.

The Enforcer

In Germany: the BSIG (Federal IT Security Act) and the BSI (Federal Office for Information Security). The BSI can audit, require registration, require incident reports, and impose fines up to **€10 million or 2% of global turnover**.

Key Takeaways

1. NIS2 is Directive (EU) 2022/2555 one EU-wide cybersecurity law covering roughly 160,000 entities.
2. Three layers apply: the NIS2 Directive (goals), the CIR 2024/2690 (detailed technical rules, directly applicable), and national law (BSIG in Germany) enforced by the BSI.
3. The directive creates personal accountability for the management body which is why leadership, not just IT, is addressed directly.

Quiz

Q1. What is the difference between an EU directive and an EU regulation?

- A. A directive applies directly; a regulation must be transposed into national law
- B. A regulation applies directly; a directive must be transposed into national law
- C. There is no difference; both apply directly
- D. A directive only applies to Essential entities; a regulation applies to all

A regulation (like the GDPR or the CIR) applies directly in every country. A directive tells each country what the result has to be, and each country writes its own national law.

Q2. What does the CIR (Commission Implementing Regulation 2024/2690) do?

- A. It replaces the NIS2 Directive entirely
- B. It sets the goals that each country must achieve
- C. It sets detailed technical requirements that apply directly in all 27 member states
- D. It designates the competent authority in each country

The CIR is a regulation that applies directly in all member states, setting detailed technical requirements.

Q3. What is the full legal chain?

- A. CIR sets goals, NIS2 sets rules, national law enforces
- B. NIS2 Directive sets goals, CIR sets detailed technical rules, national law transposes, national enforcer audits
- C. National law sets goals, NIS2 Directive sets rules, CIR enforces
- D. GDPR sets goals, NIS2 sets rules, CIR enforces

EU Directive (NIS2) → goals; EU Regulation (CIR) → detailed technical rules; national law → transposes; national enforcer → audits and fines.

Q4. Why was NIS1 replaced?

- A. NIS1 was too strict and costly for companies
- B. NIS1 only applied to digital infrastructure providers
- C. NIS1 was widely seen as inconsistent and weakly enforced, with almost no fines ever issued
- D. NIS1 was a regulation that could not be adapted to local laws

Almost no fines were ever issued under NIS1 anywhere in the EU. NIS2 was designed to fix this.

1.2 **1.2** Who Is in Scope Essential vs Important Entities

Article 3 of the NIS2 Directive sorts covered companies into two lists.

Annex I Essential Entities

Energy, Transport, Banking,
Financial market
infrastructure,
Health, Drinking water,
Wastewater,
Digital infrastructure,
ICT service management,
Public administration, Space

Proactive supervision

Max fine: €10M or 2% turnover

Annex II Important Entities

Postal & courier services,
Waste management, Chemicals,
Food production &
distribution,
Manufacturing, Digital
providers,
Research organisations

Reactive supervision

Max fine: €7M or 1.4% turnover

Size threshold: 50+ employees *or* >€10M annual turnover. Meet either criterion and operate in a listed sector: you are in scope.

The key difference: Essential entities face *proactive* supervision (audited any time, no cause needed). Important entities face *reactive* supervision (audited when triggered). **The ten measures under Article 21 apply equally to both.**

Key Takeaways

1. NIS2 covers two categories, Essential (Annex I) and Important (Annex II) with a size threshold of 50 employees or €10M turnover for both.
2. Essential entities face proactive supervision. Important entities face reactive supervision.
3. The ten measures apply equally to both categories, the difference is enforcement intensity, not compliance scope.

Quiz

Q1. What is the size threshold for most companies to fall in scope of NIS2?

- A. 250 or more employees, or €50M in turnover
- B. 50 or more employees, or more than €10M in annual turnover
- C. 10 or more employees, or more than €1M in annual turnover
- D. 100 or more employees, or more than €25M in annual turnover

The general threshold is 50+ employees or >€10M turnover in a listed sector.

Q2. What is the key difference between Essential and Important entities?

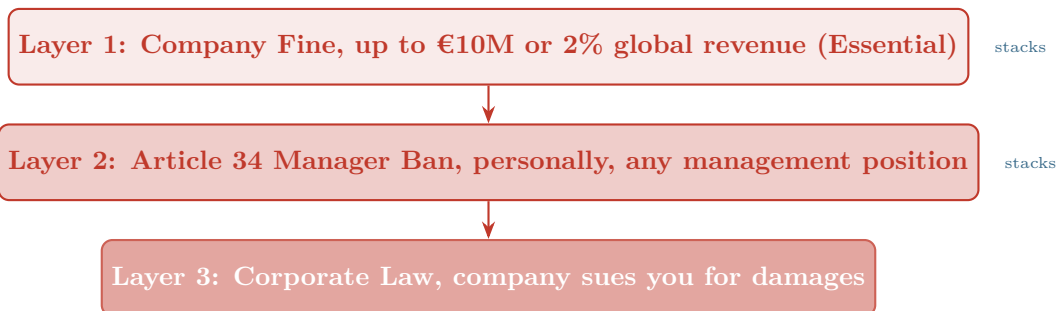
- A. Essential entities must implement all ten measures; Important entities only implement five

- B. Essential entities face proactive supervision; Important entities face reactive supervision
- C. Important entities face higher fines than Essential entities
- D. Essential entities are in Annex II; Important entities are in Annex I

Q3. Do Essential and Important entities implement different security measures?

- A. Yes, Essential entities have stricter technical requirements
- B. Yes, Important entities have additional reporting duties
- C. No, both must implement the same ten measures under Article 21
- D. No measures apply to Important entities

1.3 1.3 Penalties and the Article 34 Manager Ban



Three layers of exposure. **They stack.** The regulator can fine the company, ban you personally, and the company can sue you for damages, all for the same failure.

Article 20(1) makes this explicit: management bodies “can be held liable for infringements.”

Article 34 includes **interim management restrictions**: a temporary removal from office *while the investigation is still running*. You can be removed before the case is decided.

Key Takeaways

1. The company fine caps at €10M or 2% global revenue for Essential entities; €7M or 1.4% for Important. Member states can go higher.
2. Article 34 gives the regulator the power to ban you, personally, from holding any management position, including an interim removal while proceedings run.
3. Your national corporate law lets the company sue you personally for damages on top of both the fine and the ban.

Quiz

Q1. What is the maximum fine for Essential entities under NIS2?

- A. €7M or 1.4% of worldwide turnover
- B. €10M or 2% of worldwide annual turnover, whichever is higher
- C. €5M or 1% of worldwide turnover
- D. €20M or 4% of worldwide turnover

Q2. What does Article 34 allow the regulator to do?

- A. Only fine the company
- B. Ban an individual from holding any management position, including interim removal during investigation

- C. Shut down the company permanently
- D. Revoke the company's operating licence

Q3. How many layers of exposure does the lesson describe?

- A. One: the company fine
- B. Two: the company fine and the manager ban
- C. Three: the company fine, the Article 34 manager ban, and personal civil liability under corporate law
- D. Four: fine, ban, civil liability, and criminal prosecution

Q4. What is the maximum fine cap for Important entities?

- A. €10M or 2% of worldwide turnover
- B. €7M or 1.4% of worldwide turnover, whichever is higher
- C. €5M or 1% of worldwide turnover
- D. There is no cap for Important entities

1.4 **1.4** The Registration Obligation

Article 27 of the NIS2 Directive requires covered companies to **register with the national competent authority within three months** of becoming subject to NIS2.

What the registration must include

Company name, address, sector, contact details **including a 24/7 incident contact**, the services the company provides, the EU countries where those services are offered, and (for digital infrastructure providers) IP address ranges.

Late or incorrect registration is sanctioned separately under Article 32, its own violation, independent of any cyber incident. In Germany as of March 2026, roughly **11,500 of an estimated 29,500** in-scope companies had registered by the deadline.

Key Takeaways

1. Article 27 gives you three months from the day your company becomes covered to register, and must include a 24/7 incident contact.
2. Missing or incorrect registration is a separate fine, independent of any cyber incident, and is the easiest violation for the regulator to detect.
3. In Germany, only about 11,500 of an estimated 29,500 in-scope companies had registered by March 2026, the rest are exposed to immediate enforcement.

Quiz

Q1. How long does a company have to register after becoming covered?

- A. One month
- B. Three months
- C. Six months
- D. One year

Q2. Is missing registration a violation even without a cyber incident?

- A. No, a violation requires a cyber incident
- B. Yes, it is a separate violation sanctioned under Article 32, independent of any incident

- C. Only if the regulator has already audited the company
- D. Only for Essential entities

Q3. What specific contact must be included in the NIS2 registration?

- A. The CEO's personal mobile number
- B. A twenty-four-seven incident contact
- C. The company's general email address
- D. The CISO's LinkedIn profile

1.5 1.5 Your Duty to Approve and Oversee

Article 20(1) of the NIS2 Directive: *“the management bodies of essential and important entities approve the cybersecurity risk-management measures taken by those entities in order to comply with Article 21, oversee its implementation and can be held liable for infringements.”*

Three duties, each failing independently:

- **Approve** a formal legal act, documented, named, dated, personally signed
- **Oversee** an ongoing obligation: regular reporting from your security team, at least one formal annual review
- **Be liable** if the measures fail and the company is fined, you personally can pay

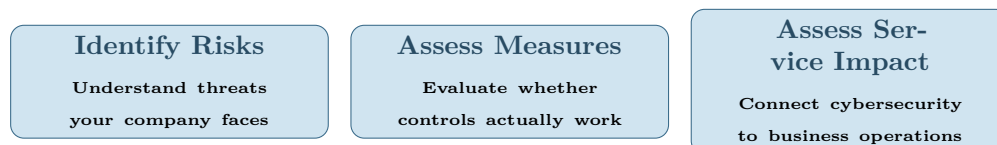
One thing most leadership teams miss: You are expected to personally *use* the controls you approved. If you approved multi-factor authentication for staff logins, you use it. A CEO who exempts themselves from the controls they approved is in direct violation an auditor can cite it as a finding.

Key Takeaways

1. Article 20(1) creates three personal duties approve, oversee, and be liable and each can fail independently.
2. Approval is a formal legal act: your name and personal signature must appear on the document.
3. You must personally follow the controls you approved exempting yourself from MFA or training is an audit finding.

1.6 1.6 Your Training Duty

Article 20(2): *“the members of the management bodies of essential and important entities are required to follow training ... in order that they gain sufficient knowledge and skills to enable them to identify risks and assess cybersecurity risk-management practices and their impact on the services provided.”*



Three competence areas required by Article 20(2). Covering only one or two fails the standard.

Frequency: “Regular” in Germany means at minimum every three years; BSI recommends annual. The training duty is **personal and non-delegable**.

Key Takeaways

1. Training must cover all three competence areas covering only one or two fails the standard.
2. Minimum every three years in Germany; annual recommended by the BSI. Non-delegable.
3. The auditor judges sufficiency based on content covered, time spent, and documentation, not on which body issued a certificate.

1.7 **1.7 Personal Liability Under Your Country's Corporate Law**

Your company gets fined €10 million for a NIS2 failure. Your supervisory board meets the next morning. The first item: whether to sue you, personally, for those €10 million, and under your country's corporate law, they are allowed to.

In many EU countries, including Germany, the **reverse burden of proof** applies to director liability. The company does not have to prove you were careless. **You have to prove you were careful.**

Your defence: the dated sign-off, the training record, the meeting minutes, the risk register with your signature. Without them, you are arguing from an empty file.

Key Takeaways

1. The EU directive creates the duty; your national corporate law turns it into a personal financial claim your own company can bring against you.
2. In Germany, the burden of proof runs against the director: you must prove due care.
3. Documentation is your only defence.

1.8 **1.8 The Business Judgment Rule Does Not Protect You**

The Business Judgment Rule protects directors from personal liability for *business decisions* made in good faith. It does **not** cover statutory duties.

The principle is called the **duty of legality**: a director must comply with applicable law. No business judgment is permitted about *whether* to follow a legal duty. "I made a reasonable business decision not to fully implement Article 21" is not a valid defence.

The SEC charged the CISO of SolarWinds personally after a supply-chain breach. The claim relied on internal documents, Slack messages, risk reports, showing a gap between external disclosures and internal reporting. Three lessons directly applicable to NIS2:

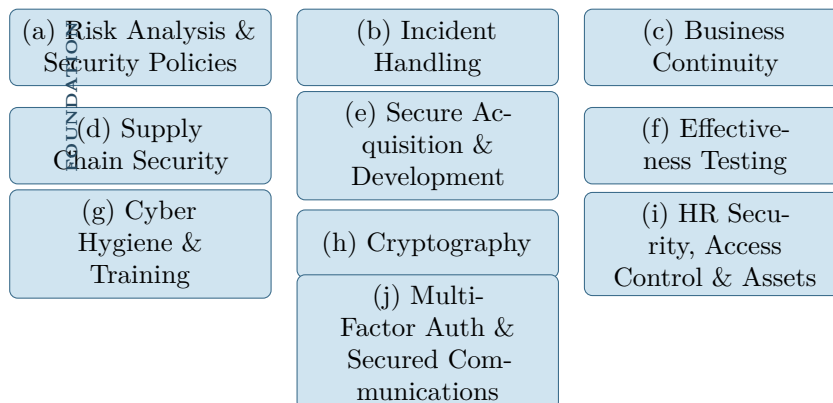
1. Internal risk reports named control gaps that leadership did not close.
2. The company's external security posture diverged from internal reports.
3. Risk information was not reaching leadership in actionable form.

Key Takeaways

1. The Business Judgment Rule protects commercial decisions, not compliance with law. Article 20 and Article 21 create statutory duties under the duty of legality.
2. "I made a reasonable business decision not to implement the measure" is not a valid defence.
3. Internal documents, risk reports, assessments, meeting minutes, are what the regulator uses to prove you knew about the gap.

1.9 1.9 The Ten Measures - Overview

There are **ten** of them. Not eight. Not twelve. Having eight out of ten is not a passing grade.



All ten apply to every covered entity. “Proportionate” means scaled to your size, not reduced to zero.

Each category needs three layers: **technical**, **operational**, and **organisational**. A firewall without a policy is incomplete. A policy without a working process is incomplete.

Key Takeaways

1. There are ten specific categories in Article 21(2) all ten apply to every covered entity, none are optional.
2. “Proportionate” means scaled to your size and risk exposure, not reduced to zero; a small company still needs all ten.
3. The common failure: most measures in good shape but one or two missing entirely. The missing ones are the violation.

1.10 1.10 All-Hazards Approach and State of the Art

Article 21(1) requires risk management “based on an all-hazards approach that aims to protect network and information systems and the **physical environment** of those systems from incidents.”

All-hazards means: cyber attacks, physical break-ins, fires, floods, power outages, supplier failures, insider threats, and human error all in scope. A risk assessment that only lists cyber attacks does not meet the standard.

State of the art means current best practice as recognised by published standards at the *time of audit*, not when you first implemented. Controls need a review cycle: **at minimum annually**.

Key Takeaways

1. All-hazards covers everything that can hit the systems, not just hackers.
2. State of the art is measured against standards current at the time of audit, not when you first implemented.
3. Your controls need a review cycle, the rule is not “implement once” but “keep current.”

Quiz

Q1. What does the all-hazards approach require?

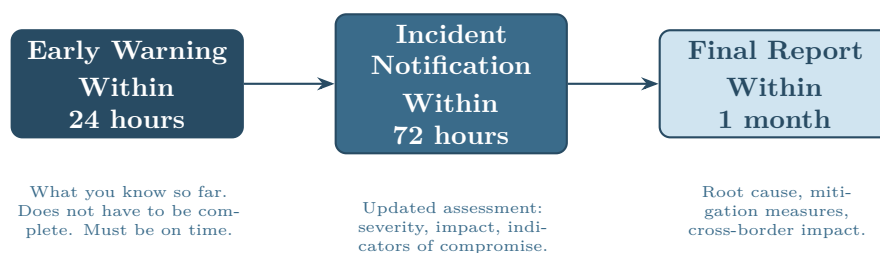
A. Protection only against cyber attacks

- B. Protection against every threat, cyber attacks, physical threats, environmental events, supplier failures, insider threats, and human error
- C. Protection only against threats that have occurred before
- D. Protection only against threats listed in the risk register

Q2. Against what point in time does the auditor judge whether controls meet “state of the art”?

- A. When the controls were first implemented
- B. The standards current at the time of the audit
- C. The date the NIS2 Directive entered into force
- D. When the company was first founded

1.11 1.11 The Reporting Cascade and Significant Incidents



Late reporting is a separate sanctionable violation.

A significant incident under CIR 2024/2690 is triggered if *any one* of: financial loss > €500,000 or 5% of turnover (whichever is lower), trade secret exfiltration, death or serious health damage, or malicious unauthorised access causing severe disruption.

Article 4 recurring rule: Two or more incidents with the same root cause within six months that together cross the threshold = one significant incident. Track root causes.

Key Takeaways

1. Significant incident threshold: €500,000 or 5% turnover (whichever is lower), trade secrets, death, serious health, or malicious access causing severe disruption.
2. Two or more same-root-cause incidents within six months that together cross the threshold count as one significant incident.
3. The cascade: 24h (early warning), 72h (notification), 1 month (final report) late reporting is its own separate fine.

1.12 1.12 The Customer Notification Duty

Two separate customer-facing duties:

- **Article 23(2) self-executing:** When a significant incident is likely to adversely affect customers, notify them without undue delay and tell them what protective measures they can take. No regulator order needed.
- **Article 36 regulator-ordered:** The regulator can instruct customer notification in the public interest.

A company that waits for a regulator order when its customers face an active threat has already failed Article 23(2).

Key Takeaways

1. Article 23(2) is self-executing, when customers face an ongoing threat, notify them without undue delay and tell them what they can do. No regulator order needed.
2. Article 36 is a separate power, but waiting for it when customers face an active threat already breaches Article 23(2).
3. Have a pre-drafted customer notification template and a defined approval chain before an incident happens.

Chapter 2

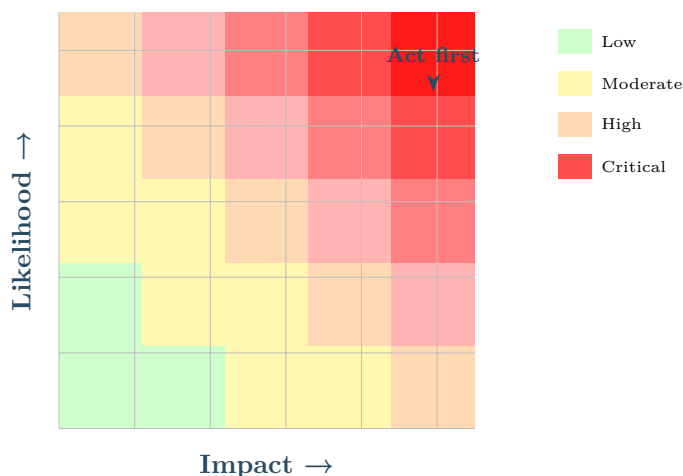
Risk and the 10 Measures

Module 2 - 15 Lessons

This module covers the risk management framework behind Article 21 and walks through each of the ten measures in detail. By the end, you will be able to walk the ten measures with your CISO and ask the right questions about each one.

2.1 **2.1** Risk = Likelihood × Impact

Article 21(1) requires “appropriate and proportionate” measures to manage cybersecurity risks. How much you spend on security has to match how exposed you are.



The risk matrix. The top-right corner, high likelihood, high impact, is where the management body’s job begins.

If you sign off on cybersecurity measures without understanding the risk picture behind them, your signature is uninformed, and an uninformed sign-off does not protect you under Article 20(1).

Key Takeaways

1. Every risk decision under NIS2 comes down to two questions, how likely and how bad.
2. The top-right corner of the matrix is where the management body’s job begins.
3. The risk register turns the budget argument from opinion into evidence, ask to see it, and check whether the dates are current.

2.2 2.2 What Is an Asset?

Equifax had a patch for a critical vulnerability. They applied it to every server except one. That one server was not on any list. 147 million records were stolen through it. The root cause was not the missing patch it was the missing inventory entry.

An asset is **anything the business depends on to operate**: servers, laptops, customer databases, cloud subscriptions, buildings, suppliers, employees with critical knowledge, and key business processes. The full list is called the **asset inventory**, and it must be kept current.

The auditor asks for the inventory *before* they ask for policies, the risk matrix, or anything else, because every other control is only as complete as the list it covers.

Ask Your Team

“Show me the asset inventory. When was it last updated, and does it include cloud subscriptions and contractor access?” If the answer covers only servers and laptops, the inventory is incomplete.

2.3 2.3 Risk Treatment Options and Risk Appetite

Four options for every risk: **Avoid, Mitigate, Transfer, Accept**. For NIS2 entities, mitigate is the workhorse, transfer and accept are rarely defensible for serious risks.

CIR 2024/2690, Annex 2.1.1: “Risk assessment results and residual risks shall be accepted by management bodies.” Your signature, dated, on the register or acceptance sheet. **This is the single most commonly missing document in audits of mid-sized companies.**

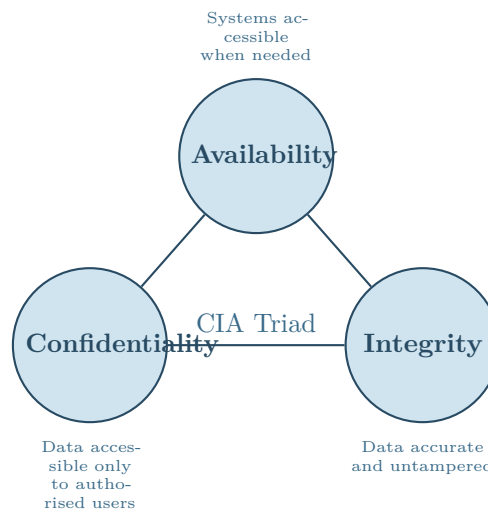
The **risk appetite** the level of risk the company is willing to live with overall, is the CEO’s boundary to set, not the CISO’s. Without it, every risk treatment decision becomes an argument.

2.4 2.4 Why Risk Management Is Continuous

Article 21 does not say “conduct a risk analysis.” It says you must take “appropriate and proportionate” measures, **present tense, continuously**. Risk management is a cycle, not a project.

Minimum review cadence: **annual** (BSI Standard 200-1, Section 7.4). Plus any time a trigger fires: major incident, significant business change, new vulnerability disclosure, regulatory change, or audit finding.

2.5 2.5 The CIA Triad and Business Impact



The **Business Impact Analysis (BIA)** translates CIA categories into business numbers: recovery targets and business consequences. The CEO's role is not to calculate the BIA it is to *validate the business assumptions in it*.

2.6 2.6 Measure 1 Risk Analysis and Information Security Policies

The CIR requires **eleven distinct policies**:

#	Required Policy
1	Information security policy (top-level your signature, your name)
2	Risk management
3	Incident handling
4	Supply chain security
5	Security testing
6	Effectiveness assessment
7	Cryptography
8	Access control
9	Privileged accounts
10	Information and asset handling
11	Removable media

The three most commonly missing in SMEs: **security testing, privileged accounts, removable media**.

The top-level policy must carry your personal signature and be published in your name. It must be reviewed **annually** with a dated management body approval.

Quiz

Q1. How many distinct policies does the CIR require for Measure 1?

- A. One comprehensive security policy
- B. Five core policies
- C. Eleven (one top-level plus ten topic-specific)

D. Three (risk, incident, access)

Q2. Which three topic-specific policies do SMEs most commonly forget?

- A. Risk management, incident handling, access control
- B. Security testing, privileged accounts, removable media
- C. Cryptography, supply chain, effectiveness assessment
- D. Backup, disaster recovery, crisis management

2.7 2.7 Measure 2 - Incident Handling

Five parts to an incident response plan: **detection, classification, response, recovery, lessons learned.**

CEO-specific entries in the plan (must be pre-assigned by name):

- Declaring a crisis
- Authorising emergency spending
- Approving external communication to customers and the regulator
- Deciding whether to pay a ransom

The plan must be tested. A **tabletop exercise**, a paper rehearsal against a scenario, conducted less than 12 months ago, with documented changes as a result.

2.8 2.8 Measure 3 - Business Continuity

NotPetya malware wiped Maersk's global IT in under two hours. Recovery cost: €300 million. The only reason it took 10 days instead of months: one backup happened to be offline due to a power cut in Ghana. Luck is not a control.

Three components: **backup management** (tested, stored separately), **disaster recovery** (RTO and RPO defined and verified by actual testing), **crisis management** (named team, pre-assigned authority, exercised annually).

RTO and RPO

RTO (Recovery Time Objective): How quickly must this system be back up after an incident?

RPO (Recovery Point Objective): How much data can the company afford to lose, measured in time?

You must attend the annual crisis exercise. BSI DER.4 names the management body in nine of sixteen requirements, absence is an audit finding.

2.9 2.9 Measure 4 - Supply Chain Security

A routine software update to 18,000 customers contained a back door planted by attackers. Every customer had to treat it as their own incident, not their supplier's.

"Supplier" under NIS2 means **anyone with access to your systems or data**, from cloud provider to the cleaning company with a key to the server room.

Four things required for each supplier:

1. Supplier inventory entry
2. Risk classification
3. Contractual clauses: incident notification, audit rights, security baseline
4. Periodic review (questionnaire, certificate, or audit)

If your supplier is breached and your customers' data leaks, the reporting duty under Article 23 and the customer notification duty under Article 36 both land on **you**, not the supplier.

2.10 **2.10** Measure 5 - Acquisition, Development, and Maintenance

Three duties: **secure acquisition** (security requirements in every purchase), **secure development** (documented standard if you write software), **vulnerability handling** (patch SLAs exist on paper, results tracked quarterly).

The single most important operational evidence: **a written patch SLA and a quarterly report on whether you are meeting it.**

Ask Your Team

"What is our patch SLA on critical vulnerabilities, and in the last quarter, on what percentage of systems did we meet it?"

2.11 **2.11** Measure 6 - Effectiveness Assessment

The **annual management review** is a discrete obligation under BSI Standard 200-1, Section 7.4. It must produce a **signed protocol** with:

- Status of the security programme since last review
- Whether previous decisions were carried out
- New threats, resource needs, residual risks accepted

The auditor's first question on Measure 6: "Show me the protocol of your last annual management review, and show me that the follow-up actions were closed." Without a dated, signed protocol, the entire measure fails the audit.

2.12 **2.12** Measure 7 - Cyber Hygiene and Training

Two halves: **cyber hygiene** (daily basics: strong passwords, MFA, regular updates, backups, cautious links) and **training** (scheduled programme).

Training applies to:

- All staff: annual awareness training
- Technical/high-risk roles: role-specific training
- Management body: its own programme under Article 20(2)

One generic e-learning course for the whole company does not satisfy this requirement. **Phishing simulations** with follow-up training for anyone who clicks are part of the programme.

A CEO who skips the phishing simulation or exempts themselves from the awareness programme has created a **personal audit finding** under BSI Standard 200-1 Principle 6.

2.13 2.13 Measure 8 - Cryptography

The cryptography policy must cover **encryption at rest** and **encryption in transit**, and must name where each applies.

Reference **BSI TR-02102** in the policy rather than hardcoding algorithm names, the guideline is updated as research evolves, so the policy stays current automatically.

Key management is where cryptography fails in practice. Ask: Where are the keys stored? If the answer is “on the same server as the data,” that is a gap. Who can access them? When were they last rotated?

2.14 2.14 Measure 9 - HR Security, Access Control, and Asset Management

The most common audit finding: **the leaver step**, a former employee still holding a live VPN login or active administrator account weeks after departure.

The **joiner-mover-leaver process**: the three handovers between HR and IT. If any one is broken, Measure 9 is broken. For critical roles, access revocation happens the moment the termination is decided, not the day the person walks out.

Privileged accounts need a dedicated policy with stronger controls and their own review cadence (CIR Annex 11.3).

2.15 2.15 Measure 10 - Multi-Factor Authentication and Secured Communications

MFA is effectively mandatory for four categories:

Remote Acc	Administrator Acco	Critical Systems	Email
------------	--------------------	------------------	-------

Secured emergency communications: An out-of-band channel that works when normal systems are compromised. If the crisis plan relies on email and email is down, the plan fails at the worst moment.

Lead-by-example (BSI Standard 200-1 Principle 6): Your own account is the first one the auditor checks. A CEO who approved MFA but exempted their own login has created a personal finding.

Ask Your Team

Check your own email account today, is MFA turned on? If not, turn it on. Ten minutes.

Quiz

Q1. For which four categories is MFA effectively mandatory?

- A. Personal email, social media, personal banking, and personal devices
- B. Remote access, administrator accounts, critical systems, and email
- C. Marketing tools, HR systems, accounting software, and the company website
- D. Board meetings, investor portals, press releases, and internal chat

Q2. What is the CEO’s own account the first one the auditor checks for MFA?

- A. Because the CEO’s account contains the most sensitive data
- B. Because BSI Standard 200-1 Principle 6 requires the management body to personally

- follow the security controls they approved
- C. Because the auditor starts alphabetically
- D. Because the regulator specifically named the CEO role in Article 21

Chapter 3

Decision Support

Module 3 - 11 Lessons

This module covers the governance decisions only you can make: what to sign, when to re-sign, how to run an audit, and how to handle the hardest scenarios, ransomware, supplier breaches, and pre-audit gap discovery.

3.1 **3.1** The Questions Every CEO Must Answer

The BSI has published a list of structured questions every management body must be able to answer. These are the most concrete practical test of Article 20(2) any EU regulator has published.

Foundation (5 questions)

- 1 Do I know whether my company falls under NIS2 and understand the scope of the law?
 - 2 Do our risk-management measures meet the law's requirements, and are they documented?
 - 3 Can I classify a significant incident correctly and report it on time?
 - 4 Are we registered correctly with the regulator, and do we keep that registration current?
 - 5 Do I understand my personal duties, training requirements, liability, and the sanctions I face?
-

The Ten Mandatory Measures (10 sub-questions)

- 6.1 Is our risk analysis up to date and aligned with current threats?
 - 6.2 Do we have a tested incident response plan?
 - 6.3 Can we recover from backup, and is our crisis management tested?
 - 6.4 Is supplier security checked and actively managed?
 - 6.5 Is security built into how we acquire, develop, and maintain systems?
 - 6.6 Do we measure the effectiveness of our security controls?
 - 6.7 Do we run cyber hygiene programmes and staff training?
 - 6.8 Do we use cryptography and encryption where required?
 - 6.9 Do we manage personnel security, access control, and asset management?
 - 6.10 Do we use multi-factor authentication and secured communications?
-

Deeper Checks (4 questions)

- 7 Does our risk analysis cover all assets, threats, vulnerabilities, and types of damage including reputational and regulatory harm?
 - 8 Do we evaluate how each risk affects availability, integrity, and confidentiality, as well as financial stability?
 - 9 Do we account for sector-specific requirements and our most critical business processes?
 - 10 Do we run scenario exercises, and have I personally participated in one?
-

Ask Your Team

Print this list and go through it with your CISO. Rate each: **confident** / **with help** / **cannot answer**. Every question in the third column is a gap your training must close.

3.2 **3.2** Sign-Off in Practice

Four questions to ask before you sign any security document:

1. **“Show me the risk analysis this policy refers to, when was it last updated?”**
2. **“What has changed since the last version I signed?”**
3. **“Has the budget to implement these measures been approved?”** A policy that promises controls the company has not funded is a policy the regulator will use against you.

4. **“Who are the named people responsible for each measure, and do they know they are named?”** Unassigned measures are intentions, not controls.

The management body decides **what and why**. The CISO decides **how**. An uninformed signature is legally void in most EU jurisdictions, and in court it works against you, not for you.

3.3 **3.3** When to Re-Sign-Off

Annual is the floor. Six types of events force re-sign-off before the annual cycle:

1. Change in leadership
2. Significant change in the business (acquisition, new geography, new product)
3. Major incident that exposed a gap
4. Regulatory change
5. Audit finding requiring remediation
6. Material change in the supplier base

Every re-sign-off documents three things: the **trigger event**, the **changes to the measures**, and the **new signature**.

3.4 **3.4** Red Flags in Your Team’s Sign-Off Process

Nine sentences that should make you put the pen down:

Red Flag	Your Response
“We have always done it this way.”	“Show me the version history.”
“Sign here, it is just a formality.”	“If it is a formality, why does it need my signature?”
“Our IT department handles this.”	“I am leadership. That makes me the person who must understand it.”
“We cannot afford that control.”	“Show me the risk assessment that says this is an acceptable residual risk.”
“We have never had a problem.”	“That is not an answer. Show me the current test results.”
“It is documented, but you cannot access it.”	“Then I will wait until I can read it.”
“Just trust the auditor.”	“The auditor has a job and I have a job. This is mine.”
“We will fix it after the audit.”	“If it is known, it is already a finding. Fix it now and I will sign the fix.”
“The previous CEO signed something similar.”	“The previous CEO is not signing this. I am.”

The rule: **if the explanation feels faster than the document, the process is broken.** Refusing to sign costs hours. Signing blind costs years.

3.5 **3.5** What You Cannot Delegate - The Checklist

Eleven non-delegable decisions, eleven signed artefacts:

1. Approval of the cybersecurity risk-management measures (top-level security policy, signed in your name)

2. **Formal acceptance of residual risks**, the single document most CEOs cannot produce
3. Approval of the security budget
4. Crisis declaration during a major incident
5. The Article 23 reporting decision (your team drafts, you approve)
6. Customer notification decisions under Article 36
7. Authorisation of any extraordinary payment (ransomware, settlement, emergency vendor)
8. Approval of all public statements during a crisis
9. Engagement of external forensics or legal counsel in major incidents
10. Resolution of conflicts between security and other business priorities when escalated
11. The annual management review, formal, documented, signed, at least once a year

The **residual risk acceptance** is the most commonly missing document in audits. Every risk the company has decided to live with must appear in the signed risk register with a rating, a description of what is being accepted, and a named owner with a review date. Your signature proves you personally reviewed what the company decided to live with.

3.6 3.6 CISO and Supervisory Board Reporting Lines

CIR 2024/2690, Annex 1.2.3: “At least one person shall report directly to the management bodies on matters of network and information system security.”

This is a **hard requirement**. A CISO reporting through IT or finance does not meet it, regardless of how competent the CISO is or how often they informally brief you.



The budget and headcount do not have to change, only the line on the chart. Then schedule a recurring monthly meeting with a standing written agenda.

3.7 3.7 What Happens During a Regulator Audit

Seven documents form the backbone of your audit file:

1. Article 21 policy set (all eleven policies)
2. Signed risk register with residual risk acceptance
3. Incident reports and lessons learned
4. Training records (yours and your staff's)
5. CISO-to-board reporting minutes
6. Asset inventory
7. Supplier contracts with the three critical clauses

Finding vs. Observation

Finding: A non-conformance, something the law requires that you do not have. Triggers a remediation order with a deadline.

Observation: Falls below good practice but does not violate the law. Does not trigger an order.

If remediation is incomplete when the auditor returns: the regulator escalates to binding instructions, public disclosure, or fines.

3.8 **3.8** Scenario - Ransomware Hits Friday Afternoon

LockerGoga ransomware shut down 40 production sites overnight. Cost: €60 million. Ransom paid: zero. The response worked because ransomware was already on the risk register, rated very likely / very serious, with a board-approved response plan.

Five decisions that belong to the CEO alone in the first 48 hours:

1. **Declare the crisis.** Only you can activate crisis procedures.
2. **Authorise emergency spending.** Forensics vendors, external counsel, incident response firm.
3. **Contain before you restore.** Restoring before forensics destroys the evidence chain.
4. **File the 24-hour early warning.** File what you know. State what is uncertain.
5. **Hold the line on payment.** Not now, and only after legal review of sanctions law.

3.9 **3.9** Scenario - Supplier Breach Affecting Your Customer Data

Cl0p ransomware group exploited a zero-day in MOVEit file-transfer software. Within weeks, data from over 2,600 organisations was stolen. Breach at the supplier. Data belonged to the customers.

Five decisions in a supplier breach:

1. Force the facts: which systems were connected, what data was in transit, over what time period?
2. Pull the contract: incident notification timelines, audit rights, indemnification.
3. File your own report, the supplier's report does not cover you.
4. Notify customers before the press does, under Article 36, hours after confirming exposure.
5. Pursue contractual remedies *calmly, after* the incident is handled.

Speed of notification decides the reputational outcome. Customers judge you on how fast you told them, not on whose system was breached.

3.10 **3.10** Scenario - Phishing Success: Significant or Not?

Four questions decide:

1. Has the attacker *used* the credentials?
2. What did those credentials access? (email only vs finance vs customer databases)

3. Was data exfiltrated?
4. Does the financial impact cross the CIR thresholds?

When genuinely uncertain, **file the early warning**. The regulator prefers “we are not sure, here is what we know” over silence. You cannot retroactively file one that should have been sent two days ago.

3.11 3.11 Scenario - Pre-Audit Gap Discovery

Three options when you find a gap two weeks before an audit:

Option	Action	Outcome
A	Hide it	Concealment found; cover-up is a separate violation
B	Fix it silently	Timestamps survive; looks like concealment
C	Fix it and disclose	Remediation order or warning, not a fine

In Option C: fix it immediately, document the discovery and timeline, then **you personally write to the auditor** before the audit what was found, when, what was done, what the new controls look like.

Key Takeaways

1. Finding your own gaps is the expected state - regulators distinguish between found-and-fixed versus hidden.
2. Hiding a gap or quietly fixing it both fail when the audit trail tells the story.
3. Good-faith disclosure, signed by the CEO, with the fix already in place, is the only option that strengthens your position.

Chapter 4

Protection

Module 4 - 6 Lessons

This module covers the protection layer around your personal exposure: why insurance is not a substitute for controls, what your D&O policy actually covers, and how to handle the first 48 hours of a crisis.

4.1 **4.1** Insurance Is Not a Substitute for Controls

Mondelez was hit by NotPetya malware and suffered \$100M in damage. Mondelez held a cyber policy with Zurich for that amount. Zurich refused the claim, arguing NotPetya was an act of war. Five years of litigation followed. Settlement: confidential.

Three things insurance does not remove:

- Regulatory fines under Article 32, most policies explicitly exclude them
- The manager ban under Article 34, no policy covers that
- The customer notification duty under Article 36, that lands on you regardless

The auditor does not accept an insurance certificate as evidence that you have implemented the ten measures. **Insurance pays after the incident. The auditor checks what you did before it.**

4.2 **4.2** D&O Insurance - What It Covers and the Cyber Exclusions

D&O insurance was designed for **business judgment claims**, the allegation that a director made a bad business decision. NIS2 violations are **statutory duty breaches**, a different legal category that sits on the wrong side of the line most D&O policies draw.

Ask Your Team

Three questions to ask your broker before every renewal:

1. "Does our current D&O policy contain a cyber liability exclusion?"
2. "If I am personally named in a claim by the regulator under Article 32(5), does this policy pay for my legal defence?"
3. "What does the policy say about statutory duty breaches?"

Get all three answers in writing, dated, and attached to the policy.

4.3 4.3 Cyber Insurance vs D&O - Different Products, Different Coverage

	Cyber Insurance	D&O Insurance
Named insured	The company	The director
Covers	Forensics, notification, business interruption	Legal defence, settlements
Designed for	Cyber incident costs	Business judgment claims
NIS2 personal fine?	No	May exclude cyber claims

The dangerous scenario: a director is sued personally for a cyber incident. The D&O policy has an explicit cyber exclusion. The cyber policy does not cover individual directors. **The director is uncovered.**

Ask your broker to produce a one-page map of which claim scenarios are covered by which policy.

4.4 4.4 Common Policy Exclusions to Read For

D&O exclusions:

- The cyber liability exclusion (explicit or buried in broader language)
- Pre-existing condition exclusion
- Sanctions exclusion
- Acts-of-war exclusion (significantly broadened after Mondelez)
- Failure-to-maintain-security clause
- Late notification clause

Cyber insurance exclusions:

- Pre-existing vulnerabilities and unpatched systems
- Acts-of-war / nation-state attack exclusion (Lloyd's tightened 2023)
- Sanctions law compliance
- Regulator fines and penalties **almost universally excluded**

4.5 4.5 First 48 Hours of Crisis Communication

Four audiences, in order: Internal first → Regulator second → Customers third → Public fourth.

Six decisions from the Maersk (NotPetya, 2017) case study:

1. Designate **one spokesperson** in the first hour
2. Issue a **holding statement within two hours** (acknowledges disruption, commits to update time)
3. **Brief internal team** before any external statement
4. **File the early warning** inside 24 hours
5. **Notify affected customers** under Article 36
6. Issue the **public statement last** after internal briefing, regulator report, and customer notification

The CEO is rarely the spokesperson on television but is **always the final approver** of every external statement. Legal review is not optional.

4.6 4.6 Ransomware Payment Decisions

Colonial Pipeline paid DarkSide \$4.5M in Bitcoin. The decryption tool was so slow they restored from backups anyway. The payment did not save time. The CEO stated a pre-agreed policy would have changed the decision. The company had no board-approved position on ransomware payment before the attack.

Three legal constraints on payment:

1. **Sanctions law** paying a sanctioned group is a violation even if you did not know. Attribution is often unclear in the first hours.
2. **Corporate law** in Germany, a ransom payment where the decryption tool fails or backups were viable can trigger personal liability under Breach of Trust (§266 StGB).
3. **Sector-specific rules** financial services, critical infrastructure, defence have additional restrictions.

Four steps before any payment: CEO approval (non-delegable), legal review (sanctions + criminal law), law enforcement coordination, documentation in the incident record.

The pre-agreed policy is the deliverable: your incident response plan needs a board-approved position on ransomware payment, signed by the CEO. Roughly 60% of payments yield usable decryption, often slower than a clean restore from backups.

Key Takeaways

1. Paying does not guarantee recovery, roughly 60% of payments yield usable decryption.
2. Sanctions law bites regardless of intent, you cannot always identify the recipient.
3. Make the payment decision before the attack, a pre-agreed policy signed by the CEO turns a crisis improvisation into a policy check.

Quiz

Q1. Why did Zurich refuse the Mondelez insurance claim?

- A. The policy had expired
- B. Zurich argued NotPetya was an act of war, triggering the acts-of-war exclusion
- C. Mondelez had not paid its premium
- D. The damages exceeded the policy limit

Q2. Which three consequences does insurance NOT remove?

- A. Business interruption, data loss, and reputational damage
- B. Regulatory fines, the manager ban, and the customer notification duty
- C. Legal costs, forensic investigation, and incident response
- D. Staff turnover, supply chain disruption, and media coverage

Q3. What should you do before any ransomware payment?

- A. Pay immediately to minimise disruption
- B. Consult the insurance broker and pay if covered
- C. CEO approval, legal review covering sanctions and criminal law, law enforcement coordination, and documentation
- D. Wait for the regulator's guidance

Chapter 5

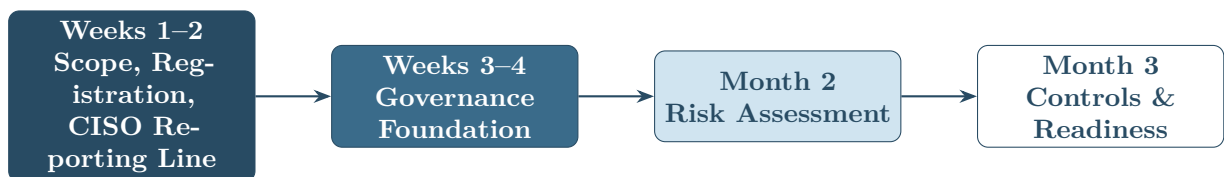
Final

Module 5 - 2 Lessons

The 90-day action plan that turns knowledge into a defensible baseline, and what your Certificate of Completion means.

5.1 **5.1** Your First 90 Days After This Course

Understanding is not compliance. The sequenced plan that turns knowledge into a defensible baseline:



Weeks 1–2:

- Confirm scope assessment (Essential or Important)
- Register with BSI if not done, late registration is worse than imperfect
- Confirm the CISO reports directly to you

Weeks 3–4:

- Sign the top-level information security policy (or re-sign if older than 12 months)
- Establish monthly CISO briefing (30 min, standing agenda, documented)
- Confirm all eleven required policies exist; assign owners to gaps

Month 2:

- Commission or review the asset inventory
- Commission or review the risk register
- Sign the residual risk acceptance (the artefact most CEOs miss)

Month 3:

- Walk the ten measures with your CISO, ask for the evidence, not the description
- Test the incident response plan (tabletop exercise, documented)
- Review top supplier contracts for three clauses
- Schedule the annual management review

Ongoing cadence:

- Monthly: CISO briefing
- Annually: policy re-sign-off, risk register review with residual risk acceptance, management review with minutes

- Every three years: management body training refresher

Compliance is not a project. The 90-day plan builds the baseline. The cadence maintains it.

Key Takeaways

1. The first two weeks are about scope, registration, and the CISO reporting line.
2. By day ninety, sign the top-level policy, the risk register with residual risk acceptance, and walk the ten measures with evidence.
3. Compliance is not a project, the 90-day plan builds the baseline; the monthly and annual cadence maintains it.

5.2 **5.2** Certificate of Completion

When you complete the course, you receive a **Certificate of Completion** stating your name, your entity, the course title, the completion date, the NIS2 articles covered, and how long you spent in the course.

The certificate is your training evidence. If an auditor asks how you have met the Article 20(2) training duty, the certificate is the first piece of paper you put in front of them.

File it in your compliance documentation in the same folder as your signed security policy, risk register, and incident response plan. Those four documents together are the backbone of your audit file.

Three actions for the next two weeks:

1. Schedule a meeting with your CISO. Bring the list of ten measures from Module 2. Ask two questions per measure: what do we have in place, and can you show me the evidence?
2. Find your current signed security policy. Check the date. Check whose name is on it. Check whether the risk analysis referenced in it exists and is current.
3. Trace the CISO's reporting line on the organisational chart. If there is anyone between the CISO and the management body, start the restructuring conversation.

Key Takeaways

1. The Certificate of Completion is training evidence for the auditor, it documents your participation, the content covered, and the time spent.
2. File the certificate alongside your signed security policy, risk register, and incident response plan.
3. Three actions in the next two weeks: meet your CISO and walk the ten measures, read and verify your signed security policy, trace the CISO reporting line.

Appendix A

Answer Key

Each entry shows the lesson number, the question number as it appears in the quiz, and the correct answer letter. Questions within each lesson are numbered Q1, Q2, Q3 from the top of that lesson's quiz.

Lesson 1.1

Q1: B
Q2: C
Q3: B
Q4: C

Lesson 1.2

Q1: B
Q2: B
Q3: C

Lesson 1.3

Q1: B
Q2: B
Q3: C
Q4: B

Lesson 1.4

Q1: B
Q2: B
Q3: B

Lesson 1.10

Q1: B
Q2: B

Lesson 2.6

Q1: C
Q2: B

Lesson 2.15

Q1: B
Q2: B

Lesson 4.6

Q1: B
Q2: B
Q3: C

Appendix B

The Non-Delegable Checklist

The eleven artefacts an auditor will ask for. Use this as a self-assessment against your current file.

#	Artefact	Done?	Last Updated
1	Top-level information security policy, signed in your name with date	☐	
2	Signed residual risk acceptance (the one most CEOs miss)	☐	
3	Security budget approval	☐	
4	Crisis management plan with your name as crisis declarant	☐	
5	Pre-agreed Article 23 reporting decision process	☐	
6	Customer notification template and approval chain	☐	
7	Pre-agreed policy on extraordinary payments (ransomware)	☐	
8	External comms approval protocol for crises	☐	
9	Forensics / legal counsel engagement authority defined	☐	
10	Business/security priority conflict escalation protocol	☐	
11	Annual management review protocol with your signature	☐	

Appendix C

The Eleven Required Policies

#	Policy	Approver	Done?
1	Information security policy (top-level)	CEO	☐
2	Risk management	Senior	☐
3	Incident handling	Senior	☐
4	Supply chain security	Senior	☐
5	Security testing	Senior	☐
6	Effectiveness assessment	Senior	☐
7	Cryptography	Senior	☐
8	Access control	Senior	☐
9	Privileged accounts	Senior	☐
10	Information and asset handling	Senior	☐
11	Removable media	Senior	☐

Senior = someone senior enough to decide; does not all require CEO signature except #1.

Appendix D

The BSI's 10 Questions Every CEO Must Answer

Print this. Rate each: **C** = confident, **H** = with help, **N** = cannot answer.

#	Question	C / H / N
1	Do I know whether my company falls under NIS2 and understand the scope?	
2	Do our risk-management measures meet the law's requirements and are documented?	
3	Can I classify a significant incident correctly and report it on time?	
4	Are we registered correctly with the regulator and do we keep it current?	
5	Do I understand my personal duties, training requirements, liability, and sanctions?	
6.1	Is our risk analysis up to date and aligned with current threats?	
6.2	Do we have a tested incident response plan?	
6.3	Can we recover from backup and is our crisis management tested?	
6.4	Is supplier security checked and actively managed?	
6.5	Is security built into how we acquire, develop, and maintain systems?	
6.6	Do we measure the effectiveness of our security controls?	
6.7	Do we run cyber hygiene programmes and staff training?	
6.8	Do we use cryptography and encryption where required?	
6.9	Do we manage personnel security, access control, and asset management?	
6.10	Do we use MFA and secured communications?	
7	Does our risk analysis cover all assets, threats, and types of damage?	
8	Do we evaluate how each risk affects CIA and financial stability?	
9	Do we account for sector-specific requirements and critical business processes?	
10	Do we run scenario exercises and have I personally participated in one?	

Appendix E

Glossary of Key Terms

All-hazards approach

Article 21(1) requirement to protect systems from every threat, not just cyber attacks, but physical threats, environmental events, supplier failures, insider threats, and human error.

Article 20(1)

The personal duty of the management body to approve cybersecurity measures, oversee their implementation, and be liable for infringements.

Article 20(2)

The personal training duty: every member of the management body must undergo cybersecurity training. Non-delegable.

Asset inventory

A complete, current list of everything the business depends on to operate, servers, software, data, people, suppliers, and processes.

BSI

Federal Office for Information Security (Bundesamt für Sicherheit in der Informationstechnik) Germany's national cybersecurity authority and NIS2 competent authority.

BSIG

Federal IT Security Act (IT-Sicherheitsgesetz) Germany's national transposition of the NIS2 Directive.

Business impact analysis (BIA)

Document that translates technical risk categories into business numbers, recovery time targets and business consequences, for each critical asset.

CIA triad

Confidentiality (data accessible only to authorised users), Integrity (data accurate and untampered), Availability (systems accessible when needed).

CIR

Commission Implementing Regulation (EU) 2024/2690, directly applicable in all 27 member states, sets detailed technical requirements including significant incident thresholds and the eleven mandatory policies.

CISO

Chief Information Security Officer - the person responsible for the cybersecurity programme.

CIR 11 policies

The eleven information security policies required by the CIR Annex (see Appendix B).

CSIRT

Computer Security Incident Response Team - the national body covered entities report significant incidents to.

Duty of legality

A director must comply with applicable law. No business judgment is permitted about whether to follow a legal duty.

Essential entity

Annex I sector company (energy, transport, banking, etc.) subject to proactive supervision.

Important entity

Annex II sector company (chemicals, manufacturing, food, etc.) subject to reactive supervision.

Joiner-mover-leaver process

The HR-IT process covering the full employee lifecycle, access granted at joining, adjusted at role changes, revoked at departure.

KPI / KRI

Key Performance Indicator (measures how well a process runs) / Key Risk Indicator (measures current risk exposure).

Management body

The legal term for the leadership team: CEO, managing directors, executive board members. Every member carries the same obligations under NIS2.

Management review

Formal annual documented review of the full security programme required by BSI Standard 200-1, Section 7.4. Must produce a signed protocol.

Non-delegable

Cannot be assigned to someone else. The training duty, the approval duty, and the eleven checklist items are all non-delegable.

Patch SLA

A written deadline for applying security patches, grouped by vulnerability severity (e.g. critical: 72 hours, high: 30 days).

Proactive supervision

Regulator can audit Essential entities at any time without cause.

Reactive supervision

Regulator audits Important entities only when triggered by an incident, complaint, or intelligence.

Residual risk

What is left after controls are applied. Must be formally accepted by the management body (CIR 2024/2690, Annex 2.1.1).

Risk appetite

The level of risk the company is willing to live with overall. The CEO sets this boundary.

RPO / RTO

Recovery Point Objective (maximum acceptable data loss, in time) and Recovery Time Objective (maximum acceptable time to restore service).

Significant incident

Defined in CIR 2024/2690: financial loss >€500,000 or 5% turnover (whichever is lower), trade secret exfiltration, death, serious health damage, or malicious access causing severe disruption.

State of the art

Current best practice as recognised by published standards at the time of audit. Controls must be reviewed and updated, not just implemented once.

Tabletop exercise

A paper rehearsal of the incident response plan against a realistic scenario. Must be conducted at least annually with documented outcomes.

About NISD2

NISD2 (www.nisd2.eu) is a free NIS2 compliance platform for companies covered by the NIS2 Directive. It provides structured documentation, audit trails, supplier registers, and the management training certificate described in this book.

This PDF is a companion to the online course. The online version includes:

- Interactive quizzes with immediate feedback
- Certificate of Completion issued on passing
- Audit trail documenting your training for regulators
- German and English versions of all content

www.nisd2.eu



NISD2